

Autentikasi JWT

Pemrograman Web (IF201)

API & Authentication

JSON Web Token

JWT adalah token terstruktur (header.payload.signature) yang digunakan untuk autentikasi stateless. Server tidak perlu menyimpan session.

Struktur JWT

Bagian	Isi
Header	Algorithm (HS256, RS256)
Payload	Claims (sub, name, exp, iat)
Signature	HMAC(header.payload, secret)

Flow Autentikasi

1. User login → server verifikasi credentials
2. Server generate JWT dengan secret key
3. Client simpan JWT (localStorage/httpOnly cookie)
4. Client kirim JWT di header: Authorization: Bearer <token>
5. Server verifikasi signature → extract claims

```
const jwt = require('jsonwebtoken');  
const token = jwt.sign({ userId: user.id, role: 'student' }, SECRET, { expiresIn: '24h' });  
const decoded = jwt.verify(token, SECRET);
```

Ringkasan

JWT stateless, cocok untuk API. Simpan di httpOnly cookie (bukan localStorage) untuk keamanan. Selalu set expiration dan verifikasi signature di setiap request.